CRA Incident Simulation

Çıktı: Incident Workflow

Ad Soyad Mustafa Önler | Grup Gece-B | Tarih

Senaryo: Saat 10:15. Baykal Abkant Pres'in servis hesabına gece 03:00'te tanınmayan bir konumdan girilmiş. PLC konfigürasyonu değişmiş olabilir; lazer koruma (ışık perdesi) parametreleri henüz doğrulanmadı. Makine çalışıyor. Vardiya sorumlusu sizsiniz.

Kavram: Bir olayda en değerli iki şey **zaman** ve **kanıt**tır. CRA'nın 24s / 72s / 14 gün yükümlülükleri, iyi bir müdahale akışının doğal kilometre taşlarıdır — ezber değil.

Görev — zaman çizgisini doldurun

1. **10:15 — ilk 15 dk:** Kimi ararsınız? İlk üç eyleminiz?

- **Arama:** Derhal Fabrika Üretim Müdürünü ve IT/Siber Güvenlik birimini (SOC) ararım.
- **Eylem 1:** Operatöre acil talimat vererek **makineyi güvenli duruma (Safe State) geçiririm** (Acil stop butonuna basarak hidrolik üst çeneyi kilitlerim ve makinenin enerjisini keserim).
- **Eylem 2:** Makinenin CNC kontrol ünitesi ve uzak bakım modülünün fabrika ağı ve internet ile olan **fiziksel/ağ bağlantısını anında keserim** (izolasyon).
- **Eylem 3:** Makineyi resetlemem veya kapatmam; adli bilişim (forensics) için logların silinmemesi adına mevcut haliyle bırakırım ve güvenlik şeridi çekerim.

2. **İlk 2 saat:** Egzoz güvende mi — nasıl doğrularsınız? Hangi kanıt korunur? Hangi hesap kapatılır?

- **Emniyet Doğrulaması:** Yetkili teknisyenle birlikte Safety PLC parametrelerini ve ışık bariyerinin muting (körleme) hassasiyetlerini çevrimdışı (offline) bir terminalden okuyarak değiştirilip değiştirilmediğini doğrularım.
- **Korunan Kanıt:** CNC işletim sisteminin, uzak bakım modülünün ve PLC'nin gece 03:00'e ait **güvenlik ve olay loglarını (Event Logs)**, ağ trafik kayıtlarını (pcap) ve bellek (RAM) imajlarını kopyalayarak koruma altına alırım.
- **Kapatılan Hesap:** Gece giriş yapılan şüpheli "servis hesabı" ve VPN/uzak erişim portları derhal devre dışı bırakılır.

3. **24 saat — CRA erken uyarı:** Hangi bilgi hazır olmalı?

Cyber Resilience Act (CRA) kapsamında 24 saat içinde yetkili kurumlara (CSIRT/ENISA) sunulması gereken **Erken Uyarı Bildirimi (Early Warning)** için şu bilgiler hazır olmalıdır: Saldırının gerçekleştiği cihaz (Baykal APHS), tespit edilen ihlalin türü (yetkisiz erişim/parametre değişimi ihtimali), olayın tespit saati ve şu anki durumu (makine izole edildi, üretim durduruldu).

4. **72 saat — CRA bildirim:** Kök neden, etki, önlem — kim ne yapıyor?

- **Kök Neden:** Açık bırakılan uzak bakım portu ve sızdırılan yetkili servis parolası üzerinden ağa girilmesi.
- **Etki:** Üretim hattında X saat duruş ve potansiyel (gerçekleşmeden engellenen) S=3 seviyesinde ölümcül ezilme tehlikesi.
- **Önlem:** Parolaların sıfırlanması, MFA (Çok Faktörlü Doğrulama) kurulumu ve Jump Server izolasyonu.
- **Kim Ne Yapıyor?:** IT/Siber Güvenlik birimi bu detaylı teknik ve adli bilişim raporunu hazırlayarak CRA gereği yetkili kurumlara **Olay Bildirimi (Incident Notification)** sunar.

5. **14 gün — son rapor:** Hangi loglar/kayıtlar korunmuş olmalı?

Kapanış raporu için saldırının başladığı andan itibaren korunan şu kayıtlar sunulmalıdır: Ağ güvenlik duvarı (Firewall) erişim logları, CNC ve Safety PLC parametre değişiklik logları, VPN/MFA kimlik doğrulama kayıtları, sistem olay görüntüleyici (Event Viewer) kayıtları ve adli imajlar zinciri.

En sık hata: "Resetleyip devam edelim" — o düğme, kanıtı sonsuza dek siler. Önce emniyet, hemen sonra kanıt.

Bu föyün çıktısı **Incident Workflow** → Evidence Pack **EP 13 Incident Response** başlığına oturur.